

2.1 Analyzing a Cyber Attack

Types of Malware

- Cybercriminals use many different types of malicious software, or malware, to carry out their activities. The use of malware is any code that can steal data, bypass access controls, or cause harm to or compromise a system. Knowing the different types and how they spread is key to containing and removing them.

Spyware:

- Spyware monitors your online activity and can log every key you press on your keyboard and capture almost any of your data, including sensitive personal information such as your online banking details. Its design is to track and spy on you. Spyware does this by modifying the security settings on your devices.
- It often bundles itself with legitimate software or Trojan horses.

Types of Malware (Cont.)

Adware:

- Often, adware installs with some software versions, and its design is to automatically deliver advertisements to a user, most often on a web browser. You know it when you see it! It's hard to ignore when facing constant pop-up ads on your screen.
- It is common for adware to come with spyware.

Backdoor:

- This malware gains unauthorized access by bypassing the normal authentication procedures to access a system. As a result, hackers can access resources within an application and issue remote system commands.
- A backdoor works in the background and is difficult to detect.

Types of Malware (Cont.)

Ransomware:

- The design of this malware is to hold a computer system or the data it contains captive until it makes a payment. Ransomware usually encrypts your information so you can't access it.
- Some versions of ransomware can take advantage of specific system vulnerabilities to lock it down. Ransomware is often spread through phishing emails that encourage you to download a malicious attachment or through a software vulnerability.

Scareware:

- This type of malware uses 'scare' tactics to trick you into taking a specific action. Scareware mainly consists of operating system-style windows that warn you that your system is at risk and needs to run a specific program to return to normal operation.
- If you agree to execute the specific program, your system will become infected with malware.

Types of Malware (Cont.)

Rootkit:

- The design of this malware is to modify the operating system to create a backdoor, which attackers can then use to access your computer remotely. Most rootkits use software vulnerabilities to access resources that shouldn't be accessible (privilege escalation) and modify system files.
- Rootkits can also modify system forensics and monitoring tools, making them very hard to detect. If a rootkit infected a computer, wipe the computer and reinstall any required software.

Types of Malware (Cont.)

Viruses:

- A virus is a computer program that, when executed, replicates and attaches itself to other executable files, such as a document, by inserting its code. Most viruses require end-user interaction to initiate activation and can act on a specific date or time.
- Viruses, such as those that display a funny image, can be relatively harmless. Or they can be destructive, such as those that modify or delete data.
- Viruses can also be programmed to mutate to avoid detection. USB drives, optical disks, network shares, or email spreads most viruses.

Trojan Horse

- This malware carries out malicious operations by masking its true intent. It appears legitimate but is very dangerous. Trojans exploit your user privileges, and image files are where you find them, audio files or games.
- Unlike viruses, Trojans do not self-replicate but act as decoys to sneak malicious software past unsuspecting users.

Types of Malware (Cont.)

Worms:

- This type of malware replicates itself to spread from one computer to another. Unlike a virus, which requires a host program, worms can run alone. Other than the initial infection of the host, they do not require user participation and can spread very quickly over the network.
- Worms share similar patterns: They exploit system vulnerabilities, have a way to propagate themselves, and all contain malicious code (payload) to cause damage to computer systems or networks.
- Worms are responsible for some of the most devastating attacks on the Internet. In 2001, the Code Red worm infected over 300,000 servers in just 19 hours.

Symptoms of Malware

Regardless of the type of malware that infects a system, you can look out for some common symptoms. These include:

- an increase in central processing unit (CPU) usage, which slows down your device
- your computer freezing or crashing often
- a decrease in your web browsing speed
- unexplainable problems with your network connections
- modified or deleted files
- the presence of unknown files, programs, or desktop icons
- unknown processes running
- programs turning off or reconfiguring themselves
- sending emails without your knowledge or consent.

2.2 Methods of Infiltration

Social Engineering

- Social engineering is manipulating people into performing actions or divulging confidential information. Social engineers often rely on people's willingness to be helpful but also prey on their weaknesses.
- For example, an attacker will call an authorized employee with an urgent problem that requires immediate network access and appeal to the employee's vanity or greed or invoke authority by using name-dropping techniques to gain this access.

Pretexting

- This is when an attacker calls an individual and lies to them to gain access to confidential data.
- For example, pretending to need a person's personal or financial data to confirm their identity.

Social Engineering (Cont.)

- **Tailgating**
 - This is when an attacker quickly follows an authorized person into a secure, physical location.
- **Something for something (quid pro quo)**
 - This is when an attacker requests personal information from someone in exchange for something, like a gift.

Denial-of-Service (DoS)

Denial-of-Service (DoS) attacks are a type of network attack that is relatively simple to carry out, even by an unskilled attacker. A DoS attack results in some interruption of network service to users, devices, or applications.

Overwhelming quantity of traffic

- This is when a network, host, or application sends an enormous amount of data at a rate it cannot handle. This causes a slow transmission or response or causes the device or service to crash.

Maliciously formatted packets

- A packet is a collection of data that flows between a source and a receiver computer or application over a network, such as the Internet. When sending a maliciously formatted packet, the receiver cannot handle it.
- For example, suppose an attacker forwards packets containing errors or improperly formatted packets that an application cannot identify. In that case, this will cause the receiving device to run very slowly or crash.

Methods of Infiltration

Distributed DoS

A Distributed DoS (DDoS) attack is similar to a DoS attack but originates from multiple coordinated sources. For example:

- An attacker builds a network (botnet) of infected hosts called zombies, controlled by handler systems.
- The zombie computers will constantly scan and infect more hosts, creating more and more zombies.
- When ready, the hacker will instruct the handler systems to make the botnet of zombies carry out a DDoS attack.

Botnet

- A bot computer is typically infected by visiting an unsafe website or opening an infected email attachment or media file. A botnet is a group of bots connected through the Internet that a malicious individual or group can control. It can have tens of thousands, or even hundreds of thousands, of bots which a command and control server typically controls.
- Activating these bots distributes malware, launches DDoS attacks, distributes spam emails, or executes brute-force password attacks. Cybercriminals will often rent out botnets to third parties for nefarious purposes.
- Many organizations, like Cisco, force network activities through botnet traffic filters to identify any botnet locations.

Botnet (Cont.)

1. Infected bots try to communicate with a command and control host on the Internet.
2. The Cisco Firewall botnet filter is a feature that detects traffic coming from devices infected with the malicious botnet code.
3. The cloud-based Cisco Security Intelligence Operations (SIO) service pushes down updated filters to the firewall that match traffic from new known botnets.
4. Alerts go out to Cisco's internal security team to notify them about the infected devices generating malicious traffic so that they can prevent, mitigate and remedy these.

On-Path Attacks

- On-path attackers intercept or modify communications between two devices, such as a web browser and a web server, to collect information from or impersonate one of the devices.
- This type of attack refers to a man-in-the-middle or man-in-the-mobile attack.

Man-in-the-middle

- A MitM attack happens when a cybercriminal takes control of a device without the user's knowledge. With this level of access, an attacker can intercept and capture user information before it sends it to its intended destination. Using these types of attacks often steals financial information.
- There are many types of malware that possess MitM attack capabilities.

On-Path Attacks (Cont.)

Man-in-the-Mobile

- A variation of man-in-middle, MitMo is a type of attack used to take control over a user's mobile device. When infected, the mobile device's instruction exfiltrates user-sensitive information and sends it to the attackers. ZeuS is one example of a malware package with MitMo capabilities. It allows attackers to capture two-step verification SMS messages sent to users quietly.

Methods of Infiltration

SEO Poisoning

- You've probably heard of search engine optimization or SEO, which is about improving an organization's website to gain greater visibility in search engine results.
- Search engines such as Google work by presenting a list of web pages to users based on their search queries. These web pages rank according to the relevancy of their content.
- While many legitimate companies specialize in optimizing websites to better position them, attackers take advantage of popular search terms and use SEO to push malicious sites higher up the search results. This technique is called SEO poisoning.
- The most common goal of SEO poisoning is to increase traffic to malicious sites that may host malware or attempt social engineering.

Methods of Infiltration

Password Attacks

Entering a username and password is one of the most popular forms of authenticating to a website. Therefore, uncovering your password is an easy way for cybercriminals to gain access to your most valuable information.

Password Spraying:

- This technique attempts to gain access to a system by 'spraying' a few commonly used passwords across many accounts. For example, a cybercriminal uses 'Password123' with many usernames before trying again with a second commonly-used password, such as 'qwerty.'
- This technique allows the perpetrator to remain undetected and avoid frequent account lockouts.

Dictionary Attacks:

- A hacker systematically tries every word in a dictionary or a list of commonly used words as a password to break into a password-protected account.

Password Attacks (Cont.)

Brute-force attacks

- The simplest and most commonly used way of gaining access to a password-protected site, brute-force attacks see an attacker using all possible combinations of letters, numbers, and symbols in the password space until they get it right.

Rainbow attacks

- Passwords in a computer system do not store as plain text but as hashed values (numerical values that uniquely identify data). A rainbow table functions as an extensive dictionary of precomputed hashes and passwords.
- Unlike a brute-force attack that has to calculate each hash, a rainbow attack compares the hash of a password with those stored in the rainbow table. When an attacker finds a match, they identify the password used to create the hash.

Password Attacks (Cont.)

Traffic Interception

- By intercepting communications, other humans and machines can easily read plain text or unencrypted passwords.
- If you store a password in clear, readable text, anyone who has access to your account or device, whether authorized or unauthorized, can read it.

Advanced Persistent Threats

- Attackers also achieve infiltration through advanced persistent threats (APTs) — a multi-phase, long-term, stealthy, and advanced operation against a specific target. For these reasons, an individual attacker often lacks the skill set, resources, or persistence to perform APTs.
- Due to the complexity and skill level required to carry out such an attack, an APT is usually well-funded and targets organizations or nations for business or political reasons.
- Its primary purpose is to deploy customized malware on one or more of the target's systems and remain there undetected.

2.3 Security Vulnerability and Exploits

Hardware Vulnerabilities/Meltdown and Spectre

Hardware vulnerabilities are most often the result of hardware design flaws.

- For example, the type of memory called RAM consists of lots of capacitors (a component that can hold an electrical charge) installed very close to one another.
- However, due to their proximity, changes applied to one of these capacitors could influence neighbor capacitors.
- This design flaw creates an exploit called Rowhammer. By repeatedly accessing (hammering) a row of memory, the Rowhammer exploit triggers electrical interferences that eventually corrupt the data stored inside the RAM.

Hardware Vulnerabilities/Meltdown and Spectre (Cont.)

Meltdown and Spectre

- Google security researchers discovered Meltdown and Spectre, two hardware vulnerabilities that affect almost all central processing units (CPUs) released since 1995 within desktops, laptops, servers, smartphones, smart devices, and cloud services.
- Attackers exploiting these vulnerabilities can read all memory from a given system (Meltdown) and data handled by other applications (Spectre). The Meltdown and Spectre vulnerability exploitations refer to side-channel attacks (the implementation of a computer system gains information). They can compromise large amounts of memory data because of the numerous times the attacks run on a system with minimal possibility of a crash or other error.

Software Vulnerabilities

- Errors in the operating system or application code usually introduce **software vulnerabilities**.
- The SYNful Knock vulnerability allowed attackers to gain control of enterprise-grade routers, such as the legacy Cisco ISR routers, from which they could monitor all network communication and infect other network devices.
- When an altered IOS version installs on the routers, this vulnerability introduces into the system. To avoid this, you should always verify the integrity of the downloaded IOS image and limit the physical access of such equipment to authorized personnel only.

Categorizing Software Vulnerabilities

Most software security vulnerabilities fall into several main categories.

Buffer Overflow:

- Buffers are memory areas allocated to an application. When writing data beyond the limits of a buffer, a vulnerability occurs. By changing data beyond the boundaries of a buffer, the application can access memory allocated to other processes. This can lead to a system crash, data compromise, or provide escalation of privileges.

Categorizing Software Vulnerabilities (Cont.)

Non-validated input:

- Programs often require input, but this incoming data could have malicious content that unintentionally forces the program to behave.
- For example, consider a program that receives an image for processing. A malicious user could craft an image file with invalid image dimensions. The maliciously crafted dimensions could force the program to allocate buffers of incorrect and unexpected sizes.

Race conditions:

- This vulnerability describes a situation where the output of an event depends on ordered or timed outputs. A race condition became a source of exposure when the required ordered or timed events did not occur in the correct order or at the proper time.

Categorizing Software Vulnerabilities (Cont.)

Weaknesses in security practices:

- Authentication, authorization, and encryption protect systems and sensitive data. Developers should use security techniques and libraries that have already been created, tested, and verified and should not attempt to create their security algorithms. These will only likely introduce new vulnerabilities.

Access Control problems:

- Access control is the process of controlling who does what and ranges from managing physical access to equipment to dictating who has access to a resource, such as a file, and what they can do with it, such as read or change the file. The improper use of access controls creates many security vulnerabilities.
- Nearly all access controls and security practices can be overcome if an attacker has physical access to target equipment. For example, no matter the permission settings on a file, a hacker can bypass the operating system and read the data directly off the disk.

Software Updates

- The goal of software updates is to stay current and avoid exploiting vulnerabilities. Microsoft, Apple, and other operating system producers release patches and updates daily. The companies or organizations responsible for them update applications such as web browsers, mobile apps, and web servers.
- Even though organizations put a lot of effort into finding and patching software vulnerabilities, they discover new vulnerabilities regularly. That's why some organizations use third-party security researchers who specialize in finding vulnerabilities in software or invest in their penetration testing teams dedicated to searching, finding, and patching software vulnerabilities before they can get exploited.
- Google's Project Zero is an excellent example of this practice. After discovering several vulnerabilities in various software used by end users, Google formed a permanent team dedicated to finding software vulnerabilities. You can find out more about Google's security research [here](#).

2.4 The Cybersecurity Landscape

The Cybersecurity Landscape

Cryptocurrency

- Cryptocurrency is digital money used to buy goods and services, using strong encryption techniques to secure online transactions. Banks, governments, and even companies like Microsoft and AT&T are very aware of its importance and are jumping on the cryptocurrency bandwagon!
- Cryptocurrency owners keep their money in encrypted, virtual 'wallets.' When a transaction occurs between the owners of two digital wallets, the recording of the details in a decentralized, electronic ledger or blockchain system takes place. This means it is carried out anonymously and is self-managed, with no interference from third parties such as central banks or government entities.

The Cybersecurity Landscape

Cryptocurrency (Cont.)

- Special computers collect data about the latest cryptocurrency transactions every ten minutes, turning them into mathematical puzzles to maintain confidentiality.
- Verification of these transactions goes through a technical and highly complex process known as 'mining.' This step typically involves an army of 'miners' working on high-end PCs to solve mathematical puzzles and authenticate transactions.
- Once verified, the ledger is updated, electronically copied, and disseminated worldwide to anyone within the blockchain network, effectively completing a transaction.

The Cybersecurity Landscape

Cryptojacking

- **Cryptojacking** is an emerging threat that hides on a user's computer, mobile phone, tablet, laptop, or server, using that machine's resources to 'mine' cryptocurrencies without the user's consent or knowledge.
- Many victims of cryptojacking didn't even know they'd been hacked until it was too late!

What Did I Learn in this Module?

- Cybercriminals use many different types of malicious software, or malware, to carry out their activities. The use of any code to steal data, bypass access controls, or cause harm to or compromise a system is malware.
- Regardless of the type of malware that infects a system, you can look out for some common symptoms. These include:
 - An increase in central processing unit (CPU) usage, which slows down your device
 - your computer freezing or crashing often
 - a decrease in your web browsing speed
 - unexplainable problems with your network connections
 - modified or deleted files
 - the presence of unknown files, programs, or desktop icons
 - unknown processes running
 - programs turning off or reconfiguring themselves
 - sending emails without your knowledge or consent.

What Did I Learn in this Module? (Cont.)

- Social engineering is manipulating people into performing actions or divulging confidential information. Social engineers often rely on people's willingness to be helpful but also prey on their weaknesses.
- **Denial-of-Service (DoS)** attacks are a type of network attack that is relatively simple to carry out, even by an unskilled attacker. A DoS attack results in some interruption of network service to users, devices, or applications.
- A Distributed DoS (DDoS) attack is similar to a DoS attack but originates from multiple, coordinated sources.
- A bot computer is typically infected by visiting an unsafe website or opening an infected email attachment or media file. A botnet is a group of bots connected through the Internet that a malicious individual or group can control.

What Did I Learn in this Module? (Cont.)

- On-path attackers intercept or modify communications between two devices, such as a web browser and a web server, to collect information from or impersonate one of the devices.
- Entering a username and password is one of the most popular forms of authenticating to a website. Therefore, uncovering your password is an easy way for cybercriminals to gain access to your most valuable information.
- **Hardware vulnerabilities** are most often the result of hardware design flaws.
- Errors in the operating system or application code usually introduce **software vulnerabilities**.

What Did I Learn in this Module? (Cont.)

- The goal of software updates is to stay current and avoid exploiting vulnerabilities.
- **Cryptocurrency** is digital money used to buy goods and services, using strong encryption techniques to secure online transactions. Banks, governments, and even companies like Microsoft and AT&T are very aware of its importance and are jumping on the cryptocurrency bandwagon.
- **Cryptojacking** is an emerging threat that hides on a user's computer, mobile phone, tablet, laptop, or server, using that machine's resources to 'mine' cryptocurrencies without the user's consent or knowledge.